UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ
Ingeniería en Tecnologías de la Información

CNO IV — REPORTE DE LABORATORIO

File Path Traversal: Validación del inicio de la ruta (start of path)

Actividad 11 — Road to Hall of Fame

PortSwigger Web Security Academy
portswigger.net/web-security/file-path-traversal/lab-validate-start-of-path

---

Alumno:	Jorge Abraham Castelo Curioca
Materia:	CNO IV
Docente:	Mtro. Servando López Contreras
Periodo:	Segundo Parcial
Documento:	Path Traversal 5 Actividad 11.pdf

1. Ficha técnica del laboratorio

Nombre del laboratorio	File path traversal, validation of start of path
Nivel	Practitioner
Tipo de explotación	File Path Traversal / Directory Traversal — evasión de validación de directorio base (prefijo obligatorio)
Objetivo del laboratorio	Cumplir con la validación del prefijo `/var/www/images/` exigida por el servidor y, al mismo tiempo, escalar directorios para recuperar el contenido del archivo de sistema `/etc/passwd`.

2. Explicación técnica de la vulnerabilidad

En esta variante, la aplicación recibe en el parámetro `filename` la **ruta completa** del recurso solicitado (por ejemplo, `/var/www/images/6.jpg`), en lugar de solo el nombre del archivo. Como mecanismo de defensa, el backend valida que la cadena recibida comience obligatoriamente con el directorio base autorizado —una comprobación equivalente a `startsWith("/var/www/images")`— antes de utilizarla para localizar el archivo.

El fallo de diseño consiste en que esta validación se aplica únicamente sobre el **prefijo textual** de la cadena, sin que el servidor resuelva (canonicalice) antes la ruta completa. Esto permite a un atacante conservar el directorio base exigido al inicio de la cadena —satisfaciendo así la validación— y concatenar inmediatamente después secuencias `../` para retroceder a través del árbol de directorios hasta alcanzar la raíz del sistema de archivos, desde donde puede referenciar cualquier archivo sensible del servidor. Esta vulnerabilidad corresponde a la categoría **A01: Broken Access Control** de OWASP Top 10 y compromete la confidencialidad de la información.

3. Procedimiento paso a paso

1. **Interceptación y reconocimiento de la ruta base.** Se inició el laboratorio y, mediante Burp Suite configurado como proxy del navegador, se revisó la pestaña Proxy / Intercept mientras se navegaba por el catálogo de productos. Se observó que cada imagen se solicita mediante `GET /image?filename=<ruta>`, y que a diferencia de laboratorios anteriores, el valor del parámetro contiene la **ruta completa en el servidor** (por ejemplo, `/var/www/images/6.jpg`) y no solo el nombre del archivo.

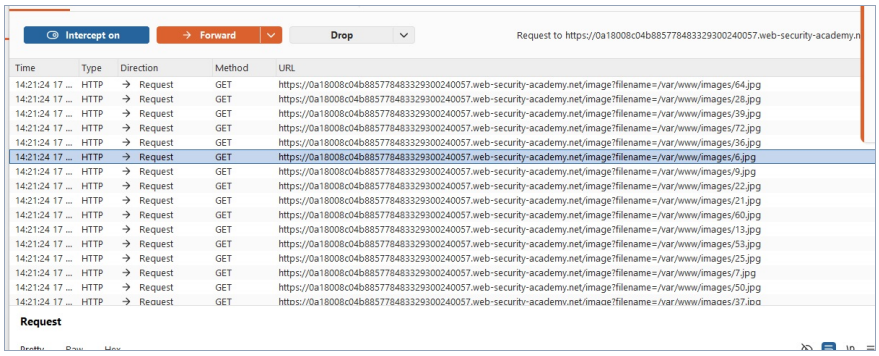


Figura 1. Burp Suite – Proxy/Intercept: peticiones GET a /image?filename=/var/www/images/<archivo>.jpg generadas al cargar el catálogo de productos.

2. **Análisis de la petición base en Repeater.** Se envió al Repeater una petición normal (`filename=/var/www/images/6.jpg`) para confirmar el comportamiento de referencia: el servidor responde `200 OK` con `Content-Type: image/jpeg` y el contenido binario de la imagen. Al intentar reemplazar la ruta completa por `/etc/passwd` o por `../../../etc/passwd` sin conservar el prefijo, la aplicación rechaza la petición, confirmando que el servidor exige que la cadena comience con `/var/www/images/`.

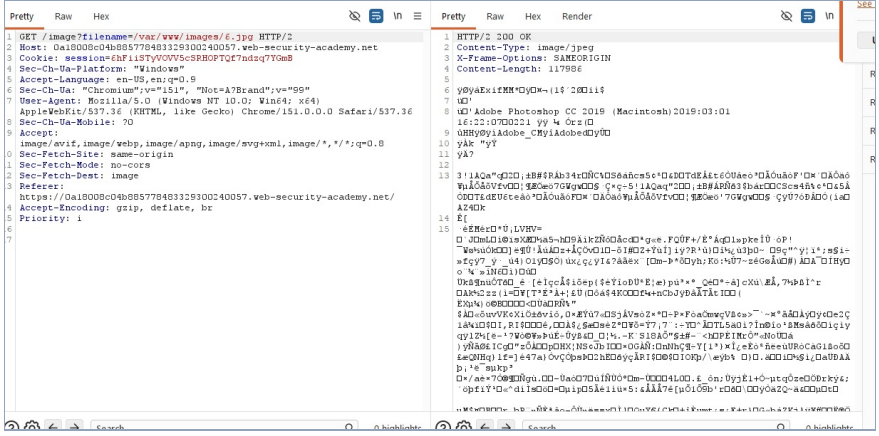


Figura 2. Repeater: solicitud de referencia con filename=/var/www/images/6.jpg y respuesta 200 OK devolviendo la imagen en formato binario.

3. **Construcción y envío del payload.** Conservando intacto el directorio base exigido por el validador, se concatenaron tres secuencias `../` seguidas del archivo objetivo, de modo que el prefijo autorizado quedara satisfecho y, al mismo tiempo, el sistema de archivos resolviera el salto hacia la raíz:

```
filename=/var/www/images/../../../etc/passwd
```

La petición modificada se envió desde el Repeater hacia el servidor para verificar si el validador era evadido.

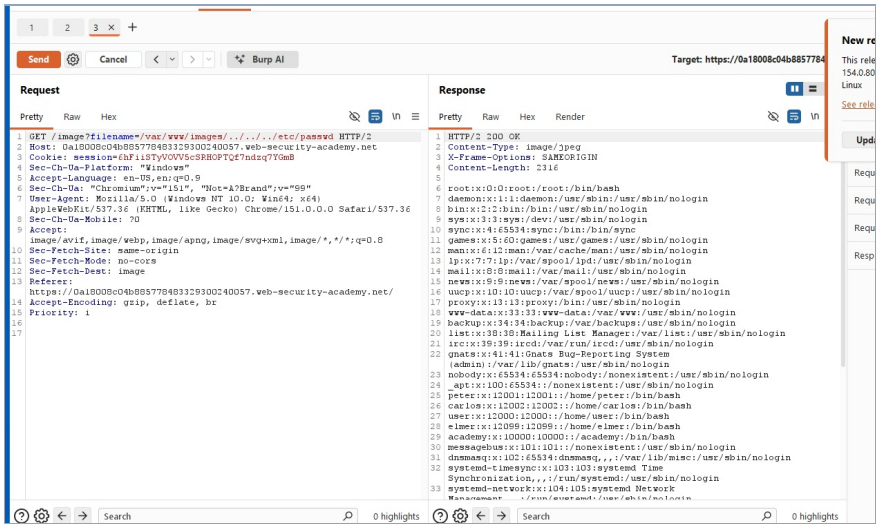


Figura 3. Repeater: solicitud con el payload /var/www/images/../../../etc/passwd y respuesta 200 OK devolviendo en texto plano el contenido completo de /etc/passwd.

4. **Confirmación de la explotación.** El validador aprobó el prefijo inicial de la cadena y el sistema de archivos resolvió los saltos relativos hasta la raíz, devolviendo el contenido íntegro de `/etc/passwd`. La plataforma de PortSwigger Web Security Academy marcó el laboratorio como resuelto, confirmando de manera oficial el éxito de la explotación.

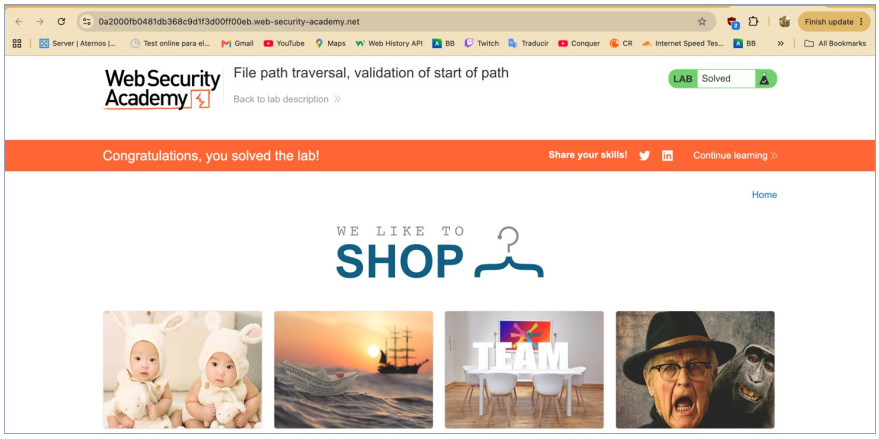


Figura 4. Confirmación "Lab Solved" otorgada por PortSwigger Web Security Academy tras la explotación exitosa.

4. Explicación del payload

```
/var/www/images/../../../etc/passwd
```

El payload se compone de dos partes con funciones distintas. La primera, `/var/www/images/`, es el prefijo exacto que el validador del servidor exige al inicio de la cadena; al incluirlo tal cual, la comprobación de tipo `startsWith()` se satisface y la petición no es rechazada. La segunda parte, `../../../etc/passwd`, aprovecha que esa misma validación no vuelve a ejecutarse después de que el sistema operativo interpreta la ruta: cada secuencia `../` sube un nivel en el árbol de directorios, de modo que las tres repeticiones cancelan exactamente los tres niveles del prefijo (`var`, `www`, `images`) y posicionan la resolución final en la raíz del sistema de archivos, desde donde `etc/passwd` apunta directamente al archivo objetivo. En otras palabras, el validador nunca llega a ver la ruta final realmente resuelta, solo la cadena tal como fue enviada.

5. Mitigación recomendada

- Canonicalizar antes de validar: resolver primero la ruta absoluta real mediante las APIs del sistema de archivos (por ejemplo, `getCanonicalPath()` en Java o `os.path.realpath()` en Python) y solo después comprobar que el resultado comience con `/var/www/images/`.
- No aceptar rutas completas como entrada: recibir únicamente el nombre base del archivo, validado contra una lista blanca, y construir la ruta completa internamente en el servidor.
- Verificar que la ruta canonicalizada permanezca dentro del directorio base permitido antes de abrir el archivo, en lugar de confiar en una comparación de texto sobre la cadena recibida.
- Ejecutar el proceso que sirve los archivos con el mínimo privilegio necesario, para limitar el impacto si la validación vuelve a fallar.